

Caso Bankitor — Arquitectura de Seguridad Completa

Corto, Mediano y Largo Plazo (TO-BE)

Trabajo académico ESAN — Docente: Javier Benvenuto Servat

Tabla de Contenidos

1. [Contexto del Problema](#)
 2. [Marco Teórico — Defensa en Profundidad \(DiD\)](#)
 3. [Clasificación y Valorización de Activos de Bankitor](#)
 4. [Glosario de Tecnologías y Terminología](#)
 5. [Corto Plazo \(0–3 meses\)](#)
 6. [Mediano Plazo \(3–6 meses\)](#)
 7. [Largo Plazo \(6–12+ meses\)](#)
 8. [Evolución Total de la Arquitectura](#)
 9. [Indicadores de Madurez \(KPIs\)](#)
 10. [Alineación Regulatoria](#)
-

1. Contexto del Problema

Bankitor es una entidad financiera que tiene más de 10 años en el mercado financiero peruano y está regulada por la **SBS**. Actualmente ya cuenta con ciertos roles y especialistas dedicados a la Ciberseguridad. Quiere reforzar su arquitectura de seguridad en la red y está dispuesta a hacer ciertos gastos o inversiones.

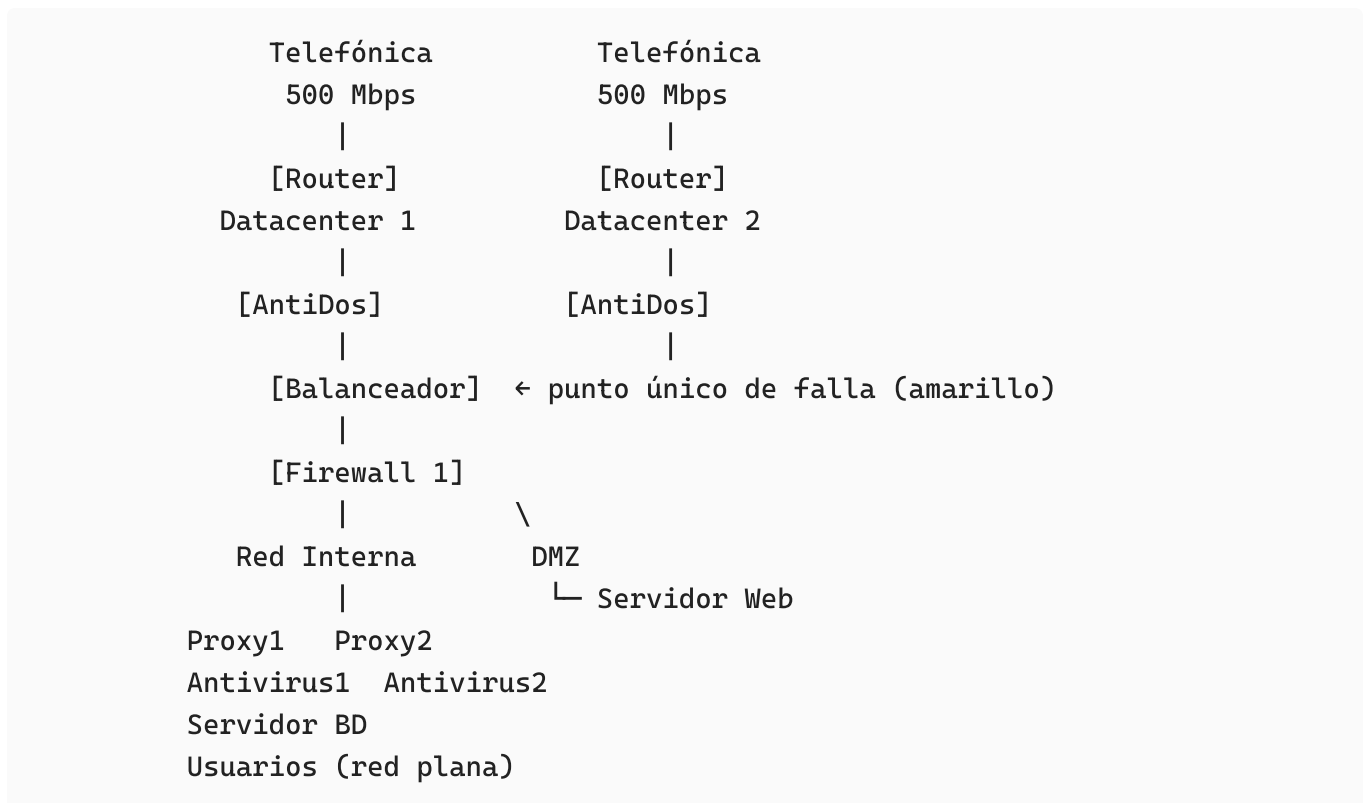
Cuentan con una estrategia, políticas de seguridad (definidas a alto nivel por la unidad de **Seguridad de la Información**) y procedimientos (definidos por **Seguridad Informática** y Producción de Sistemas). Tienen también un **SOC como servicio tercerizado** para las **TSI (Tecnologías de Seguridad Informática)** actuales.

Incidentes registrados

Incidente	Descripción	Brecha detectada
Caída de Internet	Cambio de configuración en el router de borde dejó sin conexión a Internet	No se registró qué comandos se ejecutaron ni quién los ejecutó. El análisis forense posterior no pudo reconstruir los hechos
Modificación en BD de Créditos	Saldos de deuda de clientes fueron cambiados a cero	El análisis forense no logró detectar qué DBA o aplicación ejecutó el cambio

Tienen además una **Banca por Internet** (página web informativa y transaccional) que hasta el momento no ha tenido ninguna brecha de seguridad, pero que representa un riesgo latente que se debe atender de forma proactiva.

Diagrama AS-IS (situación actual)



Problemas identificados en el AS-IS:

- Router de borde **sin trazabilidad** de comandos ejecutados.
- Base de datos de créditos **sin auditoría SQL**.
- Balanceador **sin Alta Disponibilidad** (punto único de falla).
- Firewall **sin Alta Disponibilidad**.
- Red interna **plana** (sin segmentación por dominios de seguridad).
- SIEM/SOC sin casos de uso configurados para los activos críticos.

- Banca por Internet sin WAF.

2. Marco Teórico — Defensa en Profundidad (DiD)

Esta sección está basada directamente en la teoría enseñada por el docente Javier Benvenuto Servat en ESAN.

2.1 ¿Qué es Defense in Depth (DiD)?

Defense in Depth (DiD) es un **modelo o enfoque de Ciberseguridad** (también llamado "abordaje" o "approach").

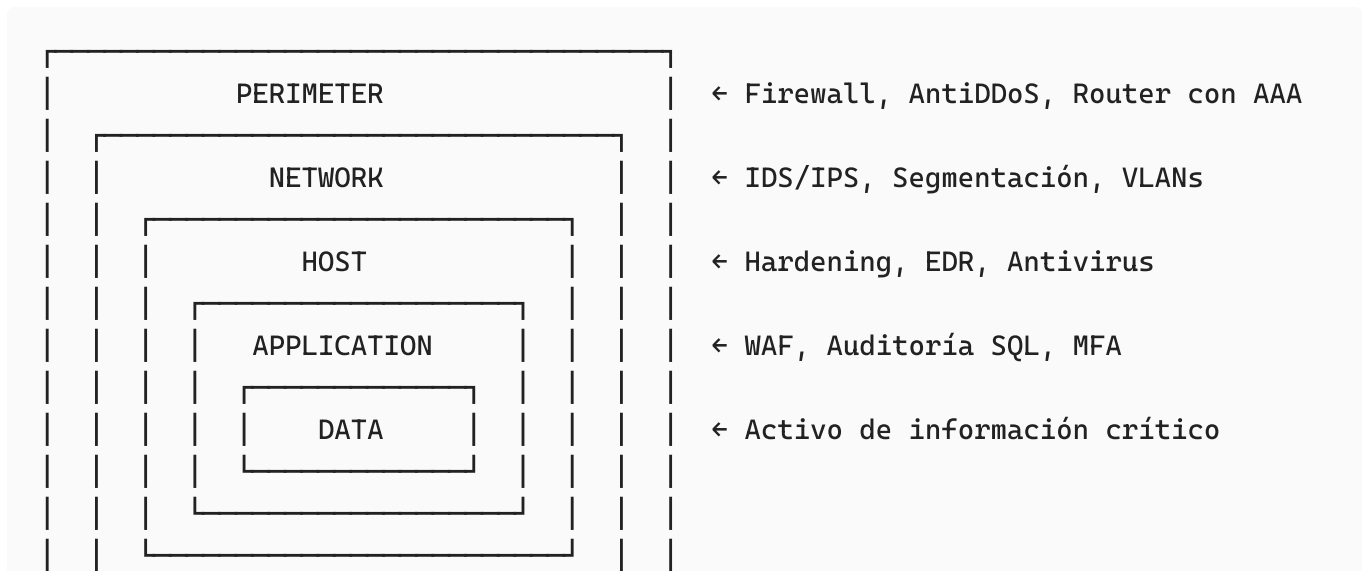
Importante: DiD **no es una estrategia**. La estrategia va más allá de la elección de un modelo: tiene que ir acompañada del apetito del riesgo y la elección de qué se va a priorizar (cumplimiento, buenas prácticas, estándares, ISOs, frameworks, etc.) y cómo.

DiD incluye una serie de **mecanismos y controles de Ciberseguridad que se superponen cuidadosamente** en una red informática para proteger la **confidencialidad, la integridad y la disponibilidad** de la red y los datos que contiene.

Si bien ninguna mitigación individual puede detener todas las amenazas cibernéticas, juntas brindan mitigaciones contra una amplia variedad de amenazas, al tiempo que incorporan **redundancia** en caso de que falle un mecanismo. Este enfoque refuerza significativamente la seguridad de la red contra muchos vectores de ataque.

2.2 Componentes lógicos del DiD (5 capas)

Los componentes lógicos son los **puntos de control y sus capas**. Son conceptuales y no necesariamente reflejan la realidad física:



Consideraciones importantes del docente:

- **El Perímetro:** Probablemente siempre tengamos uno externo, pero no es el único. Podemos tener varios de acuerdo a la segmentación de la red y los **dominios de seguridad** creados en la empresa.
- **La Red:** No toda es plana ni propia.
- **El Host:** Puede estar en varias ubicaciones y contener una o más aplicaciones.
- **Las Aplicaciones:** No dependen de un solo Host.
- **La Data:** No siempre está al último y tiene estados: **en tránsito, en reposo o en proceso**.

Corrección conceptual importante: El objetivo primordial a ser resguardado son los **activos de información (Data)**, no los dispositivos (Device), salvo que se trate de un dispositivo de **infraestructura crítica** (como el router de borde de Bankitor).

2.3 Los 3 defectos del modelo DiD y cómo los abordamos

El docente señala que el DiD clásico tiene tres defectos que hay que tener en cuenta al diseñar la arquitectura:

Defecto	Descripción	Cómo lo abordamos en Bankitor
Punto de vista de Arquitectura de Red	Supone un camino directo Internet → gateway → host. Las redes modernas son complejas.	Diseñamos con dominios de seguridad (DMZ, VLANs, perímetros internos), no solo un firewall perimetral
Capacidades superpuestas o descontinuadas	Gasto excesivo en herramientas que abordan el mismo vector. Ej: NIPS y HIPS con las mismas firmas.	Cada TSI cubre una capa distinta del DiD; no duplicamos vectores de ataque
Perspectiva de amenaza limitada	No toma en cuenta ningún modelo Kill-Chain. No incluye inteligencia de amenazas, respuesta y resiliencia.	Largo plazo: incorporamos Threat Intelligence, SOAR y ejercicios Red Team

2.4 Modelo OSI y vectores de ataque — selección de TSI por capa

El docente enseña que hay que tener en cuenta las **7 capas del modelo OSI**, los protocolos y vectores de ataque para luego definir qué TSI se pone por capa:

Capa OSI	Layer	Protocolos	Vectores de ataque	TSI aplicada en Bankitor
7 Aplicación	Application	HTTP, HTTPS, FTP, SMTP, DNS	Malware, DoS, SQL Injection, Browser Hijacking, Buffer Overflow	WAF , Auditoría SQL, EDR
6 Presentación	Presentation	Cifrado, SSL	Malformed SSL, SSL Stripping, Worms	TLS 1.2/1.3 , WAF
5 Sesión	Session	Web Sockets, Session cookies	Session Hijacking, DoS	MFA , WAF
4 Transporte	Transport	TCP, UDP, SSL	TCP Flood, TCP Sequence Prediction	AntiDDoS , Firewall
3 Red	Network	IP, ICMP	Spoofing, Hijacking, Ping Floods, MiTM	Firewall HA , IDS/IPS, AntiDDoS
2 Enlace	Data Link	MAC, Ethernet	MAC Spoofing, Switch looping, Traffic analysis	DHCP Snooping , DAI (mediano plazo)
1 Físico	Physical	Cables, WiFi	Wire Tapping, Jamming, Tampering	Controles físicos del DC (asumido)

2.5 Cyber Kill Chain — por qué es importante para el análisis

El docente presenta el modelo **Cyber Kill Chain** (Lockheed Martin) como referencia para entender cómo los atacantes operan y en qué etapa nuestros controles deben actuar:

Etapas	Descripción	TSI de Bankitor que actúa
1. Reconnaissance	El atacante recopila información sobre la víctima	AntiDDoS, WAF (detecta escaneos)
2. Weaponization	Prepara el exploit con un backdoor	Threat Intelligence (largo plazo)
3. Delivery	Entrega el payload (email, web, USB)	Proxy, Antivirus/EDR, WAF
4. Exploitation	Explota una vulnerabilidad	WAF, Gestión de Vulnerabilidades, Hardening
5. Installation	Instala malware en el activo	EDR, Antivirus, Hardening del Host

Etapas	Descripción	TSI de Bankitor que actúa
6. Command & Control (C2)	Canal de comunicación para controlar la víctima	Proxy (bloquea dominios C2), IDS/IPS
7. Actions on Objectives	El atacante logra su objetivo (robo, modificación)	Auditoría SQL, SIEM/SOC, PAM

3. Clasificación y Valorización de Activos de Bankitor

Antes de definir controles, el docente enseña que se deben clasificar y valorar los activos de información. Los controles más exhaustivos se asignan a los activos de mayor valoración. Como no se puede hacer todo en paralelo, hay que **secuenciar actividades en base a una priorización**.

3.1 Activos identificados en Bankitor

Tipo de activo	Activo	Valoración (1–5)	Nivel
Datos/Información [D]	BD de créditos (saldos de deuda)	5	Crítico
Servicios [S]	Banca por Internet	5	Crítico
Red Comunicaciones [COM]	Router de borde DC1 y DC2	5	Crítico
Red Comunicaciones [COM]	Firewall, Balanceador	4	Severo
Datos de carácter personal [DP]	Datos de clientes	5	Crítico
Software [SW]	Aplicación de banca web	4	Severo
Hardware [HW]	Servidores BD, Web	4	Severo
Personal [P]	DBAs, Administradores de red	4	Severo

3.2 Business-Critical Subset (subconjunto crítico para el negocio)

El docente enseña que en Ciberseguridad el alcance debe priorizar el **subconjunto de sistemas críticos para el negocio**: la intersección entre **Servicios, Activos de Información y Sistemas Físicos**.

Para Bankitor, ese Business-Critical Subset es:

- **BD de créditos** → activo de información más sensible (incidente 2)

- **Router de borde** → infraestructura crítica que afecta disponibilidad (incidente 1)
- **Banca por Internet** → servicio crítico expuesto (riesgo latente)

Todo nuestro diseño TO-BE prioriza estos tres elementos primero, antes de mejorar otros controles. Esta es la razón por la que el corto plazo está enfocado en ellos.

4. Glosario de Tecnologías y Terminología

Las secciones marcadas con ★ corresponden a TSI enseñadas directamente por el docente.

Las marcadas con + son controles adicionales (valor agregado) que complementan el modelo DiD pero no fueron cubiertos en clase.

★ TSI — Tecnologías de Seguridad Informática

Qué es: Término usado en el caso Bankitor para referirse a las herramientas, mecanismos y controles de seguridad implementados. El SOC de Bankitor gestiona las TSI actuales.

★ AAA (Authentication, Authorization, Accounting)

Qué es: Framework de control de acceso con tres funciones separadas:

- **Autenticación:** Verifica la identidad del usuario (¿quién eres?).
- **Autorización:** Define qué acciones puede realizar ese usuario (¿qué puedes hacer?).
- **Accounting (Auditoría/Registro):** Registra exactamente qué hizo ese usuario, qué comandos ejecutó y cuándo (¿qué hiciste?).

Capa DiD donde actúa: Perímetro y Red (dispositivos de infraestructura crítica).

Por qué resuelve el incidente 1 de Bankitor: Sin AAA, el router de borde no tenía registro de los comandos ejecutados. El análisis forense no pudo reconstruir qué cambio causó la caída. Con AAA activo, cada comando queda registrado con usuario, hora e IP de origen.

★ TACACS+ — Por qué elegimos TACACS+ y no RADIUS

TACACS+ (Terminal Access Controller Access Control System Plus) es el protocolo elegido para implementar AAA en los dispositivos de red de Bankitor (routers y firewalls).

¿Por qué TACACS+ y no RADIUS?

Característica	TACACS+	RADIUS
Separación de AAA	Sí — cada función es independiente	No — autenticación y autorización van juntas
Registro de comandos	Sí — comando por comando	No — solo registra la sesión, no los comandos
Cifrado del paquete	Todo el paquete	Solo la contraseña
Protocolo de transporte	TCP (confiable)	UDP (no confiable)
Granularidad de autorización	Por comando	Por servicio/protocolo
Uso principal	Administración de dispositivos de red	Acceso de usuarios (VPN, WiFi)

Conclusión: Para resolver el incidente 1 de Bankitor (falta de trazabilidad de comandos en el router), TACACS+ es la única opción correcta. RADIUS no registra los comandos ejecutados y no permitiría reconstruir el análisis forense.

Ejemplo de registro TACACS+ que habría evitado el incidente:

```
Usuario:  jperez
Equipo:   Router Borde DC1
Comando:  interface g0/1 shutdown
Hora:     22:15:03
Origen IP: 10.10.50.20
Resultado: Aceptado
```

★ **Análisis Forense (Digital Forensics)**

Qué es: Proceso de investigación posterior a un incidente de seguridad para reconstruir qué ocurrió, quién lo hizo y cómo. Requiere que los sistemas hayan generado y conservado registros (logs) durante el incidente.

Relevancia para Bankitor: Ambos incidentes fallaron en el análisis forense por falta de registros. El diseño TO-BE garantiza que todos los activos críticos generen logs auditables

enviados al SIEM.

★ Syslog

Qué es: Protocolo estándar para el envío de mensajes de registro (logs) desde dispositivos de red, servidores y aplicaciones hacia un servidor centralizado (el SIEM).

Capa DiD: Aplica en todas las capas — es el mecanismo de auditoría transversal del modelo DiD.

Por qué es crítico: Sin Syslog centralizado, los logs quedan aislados en cada equipo y se pierden si el equipo falla o es reiniciado por el atacante. El análisis forense queda inutilizado.

★ Dominio de Seguridad (Security Domain)

Qué es: Término del docente para referirse a segmentos de red agrupados por nivel de confianza, función o tipo de activos que requieren el mismo tipo de protección. En la arquitectura de Bankitor creamos dominios de seguridad para corregir la red plana del AS-IS.

Dominios definidos para Bankitor:

- **Dominio Internet** — red no confiable, origen de amenazas externas
 - **Dominio DMZ** — servicios expuestos (Banca por Internet)
 - **Dominio de Aplicaciones** — servidores internos de aplicación
 - **Dominio de Base de Datos** — activos de información críticos
 - **Dominio de Administración** — accesos privilegiados (PAM, SIEM, Bastion)
 - **Dominio de Usuarios** — PCs de empleados
 - **Dominio de Backups** — servidores de respaldo
-

★ Firewall Perimetral en Alta Disponibilidad (HA)

Qué es: TSI que controla y filtra el tráfico entre dominios de seguridad basándose en reglas definidas. En HA (Alta Disponibilidad), hay dos unidades en configuración activo/pasivo.

Capa DiD donde actúa: Perímetro (entre Internet y DMZ) y Red (entre dominios internos).

Por qué HA: Un firewall único que falla puede dejar sin control los flujos entre dominios. Con HA hay failover automático sin impacto en el servicio.

★ DMZ (Zona Desmilitarizada)

Qué es: Dominio de seguridad intermedio entre Internet y la red interna. Aloja servicios que deben ser accesibles desde Internet pero que no deben tener acceso directo a los activos de información internos.

Capa DiD donde actúa: Perímetro — define el límite entre el dominio Internet y los dominios internos.

Qué va en la DMZ: Servidor Web, portal de Banca por Internet.

Qué NO va en la DMZ: BD de créditos, core bancario, consolas administrativas.

Por qué la separación importa: Si un atacante compromete el servidor web en la DMZ, el daño queda contenido en ese dominio de seguridad. No puede acceder a la BD de créditos ni a la red interna.

★ AntiDDoS

Qué es: TSI que protege la disponibilidad del servicio ante ataques **DDoS (Distributed Denial of Service)**: ataques volumétricos que envían tráfico masivo desde miles de fuentes para saturar un servicio.

Capa DiD donde actúa: Perímetro — filtra el tráfico antes de que llegue a capas internas.

Capa OSI: Capas 3 y 4 (Red y Transporte) — protege contra IP Floods, TCP Floods, ICMP Floods.

★ Balanceador de Carga en Alta Disponibilidad (HA)

Qué es: TSI que distribuye el tráfico entrante entre múltiples servidores. En HA hay dos balanceadores (activo y pasivo).

Problema en el AS-IS: El balanceador actual es punto único de falla (SPOF — Single Point of Failure). Si cae, ningún usuario puede acceder a la Banca por Internet aunque los servidores estén funcionando. Impacto directo en **disponibilidad** del activo crítico.

★ WAF (Web Application Firewall)

Qué es: TSI especializada en proteger aplicaciones web. Analiza el contenido de las solicitudes HTTP/HTTPS para detectar y bloquear ataques a nivel de aplicación.

Capa DiD donde actúa: Aplicación (capa 7 del modelo OSI).

Diferencia con el Firewall tradicional: El firewall actúa en capas 3-4 (red/transporte). El WAF actúa en capa 7 (aplicación) e inspecciona el contenido dentro del tráfico HTTPS permitido por el firewall.

Ejemplo concreto:

```
Atacante envía: GET /consulta?id=1 OR 1=1--  
→ Firewall: ve tráfico HTTPS válido → PERMITE (capa 3-4)  
→ WAF:      ve intento de SQL Injection → BLOQUEA (capa 7)
```

Ataques que detecta y bloquea (OWASP Top 10):

- SQL Injection (inyección de código SQL en formularios o URLs)
- XSS — Cross-Site Scripting (inyección de JavaScript malicioso)
- Fuerza bruta (intentos masivos de login)
- Bots (tráfico automatizado no autorizado)
- Manipulación de parámetros

★ SQL Injection

Qué es: Ataque de capa 7 (Aplicación) donde el atacante inserta código SQL malicioso en campos de entrada para manipular la base de datos directamente.

Impacto: Robo, modificación o eliminación de datos. Vector de ataque directo contra el activo de información más crítico de Bankitor (BD de créditos).

★ Auditoría SQL

Qué es: Función de la base de datos que registra todas las operaciones ejecutadas: quién las ejecutó, desde qué IP, qué sentencia SQL fue, cuántas filas afectó y cuándo.

Capa DiD donde actúa: Aplicación y Data — protege el activo de información más crítico.

Resuelve el incidente 2 de Bankitor: El cambio masivo de saldos a cero no dejó rastro en el AS-IS. Con auditoría SQL activa, el SIEM habría recibido:

ALERTA CRÍTICA – Modificación masiva en tabla de créditos

Tabla: credits
Campo: saldo_deuda
Nuevo valor: 0
Filas afect.: 150
Usuario DB: app_creditos
IP origen: 10.10.40.25
Hora: 02:15:33 AM

★ Hardening (Endurecimiento de Hosts)

Qué es: Proceso de reducir la superficie de ataque de un sistema desactivando servicios innecesarios, cerrando puertos no usados, eliminando usuarios por defecto y aplicando configuraciones seguras.

Capa DiD donde actúa: Host.

★ Antivirus / EDR

Qué es: TSI de la capa Host del modelo DiD.

- **Antivirus:** Detecta malware conocido por firmas (listas de amenazas conocidas).
- **EDR (Endpoint Detection and Response):** Detecta comportamientos maliciosos en tiempo real, incluyendo amenazas nuevas o desconocidas.

Capa DiD donde actúa: Host — detección de malware y comportamientos en el endpoint.

★ Proxy / Control de Navegación

Qué es: TSI intermediaria para la salida a Internet de usuarios internos. Filtra sitios maliciosos, registra navegación y detecta comunicación con dominios de **Command & Control (C2)** de malware.

Capa DiD donde actúa: Red — controla el tráfico saliente del dominio de usuarios.

Relevancia Kill Chain: Actúa en la fase 6 (C2) — bloquea la comunicación del malware instalado con su servidor de control.

★ SIEM (Security Information and Event Management)

Qué es: Plataforma que centraliza, normaliza, correlaciona y analiza los logs de todos los mecanismos y controles del modelo DiD en tiempo real. Es el sistema que alimenta al SOC.

Capa DiD donde actúa: Transversal a todas las capas — no está en la ruta del tráfico, solo recibe eventos.

Flujo de logs hacia el SIEM:

```
Capa Perímetro: Router → SIEM | AntiDDoS → SIEM | Firewall → SIEM
Capa Red:       Balanceador → SIEM | IDS/IPS → SIEM
Capa Host:      Servidor Web → SIEM | EDR → SIEM
Capa Aplicación: WAF → SIEM | Auditoría SQL → SIEM
Dominio Usuarios: Proxy → SIEM | Antivirus → SIEM
```

★ SOC (Security Operations Center)

Qué es: Centro de operaciones de seguridad — el equipo humano que opera las TSI, monitorea las alertas del SIEM, investiga incidentes y coordina la respuesta. En Bankitor es un servicio tercerizado.

★ MFA (Autenticación Multifactor)

Qué es: Sistema que requiere dos o más factores para autenticar a un usuario, protegiendo accesos aunque la contraseña sea robada.

Capa DiD donde actúa: Perímetro y Aplicación — punto de control de identidad.

Factores:

- Algo que sabes: contraseña
- Algo que tienes: código TOTP (Google/Microsoft Authenticator), token físico
- Algo que eres: huella dactilar

★ VPN (Virtual Private Network)

Qué es: Canal de comunicación cifrado para acceso remoto seguro. Los administradores acceden a través de VPN con MFA obligatorio.

Capa DiD donde actúa: Perímetro — punto de control de acceso remoto.

★ Bastion Host / Jump Server

Qué es: Servidor intermediario altamente asegurado desde el cual los administradores acceden a los dispositivos críticos. Implementa un punto de control adicional en el dominio de administración.

Flujo correcto: Administrador → VPN + MFA → Bastion → Router / Firewall / BD

Flujo incorrecto (AS-IS): Administrador → Conexión directa al router ← sin punto de control

★ IDS/IPS (Intrusion Detection/Prevention System)

Qué es: TSI que analiza el tráfico de red en busca de patrones de ataque.

- **IDS:** Detecta y alerta (sin bloquear).
- **IPS:** Detecta y bloquea automáticamente.

Capa DiD donde actúa: Red — detecta ataques que pasaron el perímetro (firewall).

Diferencia con el Firewall: El firewall decide por reglas de IP/puerto. El IDS/IPS analiza el contenido del tráfico en busca de patrones de ataque (firmas). Son TSI complementarias, no superpuestas (resuelve el defecto 2 del DiD que señala el docente).

★ PAM (Privileged Access Management)

Qué es: Plataforma que controla, audita y gestiona todos los accesos de usuarios con privilegios elevados (DBAs, administradores de red, etc.).

Capa DiD donde actúa: Aplicación y Data — punto de control sobre el acceso a activos críticos.

Qué agrega sobre el Bastion básico:

Función	Bastion básico	PAM

Centraliza accesos	Sí	Sí
Graba sesiones (video+texto)	No	Sí
Rotación automática de contraseñas	No	Sí
Bóveda de contraseñas	No	Sí
Acceso just-in-time	No	Sí

★ VLANs (Dominios de Seguridad Internos)

Qué es: Segmentación lógica de la red interna en dominios de seguridad separados.
Corrección directa del problema de red plana del AS-IS.

Capa DiD donde actúa: Red — crea múltiples perímetros internos.

+ Backup de Configuración (*control adicional — valor agregado*)

Qué es: Copia automatizada de la configuración de dispositivos de red almacenada en repositorio centralizado. Permite comparar antes/después de un cambio y hacer rollback en minutos.

Por qué lo incluimos: Es el mecanismo de recuperación directo para el incidente 1. Sin backup, incluso con TACACS+ sabríamos quién hizo el cambio pero no podríamos revertirlo rápidamente.

+ Gestión de Vulnerabilidades (*control adicional — valor agregado*)

Qué es: Proceso continuo de identificar, priorizar y remediar debilidades técnicas (usando escáneres como Nessus o Qualys) antes de que un atacante las explote. Clasificación por CVSS (0-10).

+ DLP (Data Loss Prevention) (*control adicional — valor agregado*)

Qué es: TSI que monitorea y controla el movimiento de activos de información sensibles para evitar exfiltración no autorizada. Aplica en correo, proxy, endpoint y nube.

+ Zero Trust (*control adicional — valor agregado*)

Qué es: Modelo de seguridad complementario al DiD basado en "Nunca confíes, siempre verifica." Toda solicitud de acceso debe autenticarse y autorizarse independientemente de su origen (interno o externo). Se construye progresivamente sobre los controles del corto y mediano plazo.

+ SOAR (*control adicional — valor agregado*)

Qué es: Security Orchestration, Automation and Response. Automatiza la respuesta a incidentes mediante playbooks (guiones predefinidos). Requiere madurez del SIEM. Aborda el defecto 3 del DiD (perspectiva de amenaza limitada — incluye respuesta y resiliencia).

+ UEBA (*control adicional — valor agregado*)

Qué es: User and Entity Behavior Analytics. Detecta comportamientos anómalos usando machine learning y línea base, sin necesidad de reglas fijas. Complementa al SIEM. El cambio de saldos a cero habría sido detectado como anomalía de volumen y horario.

+ Microsegmentación (*control adicional — valor agregado*)

Qué es: Segmentación a nivel de proceso individual (más granular que VLANs). Cada aplicación solo se comunica con lo estrictamente necesario. Extiende el concepto de dominio de seguridad al nivel de workload.

+ API Gateway (*control adicional — valor agregado*)

Qué es: Punto único de entrada para APIs de banca digital con autenticación de tokens, rate limiting y validación de esquemas. Complementa al WAF en la capa de Aplicación.

+ DevSecOps (*control adicional — valor agregado*)

Qué es: Integración de seguridad en el ciclo de desarrollo de software. Incluye análisis estático (SAST), análisis de dependencias (SCA) y análisis dinámico (DAST) antes del despliegue.

+ Threat Intelligence (*control adicional — valor agregado*)

Qué es: Consumo de fuentes de información sobre amenazas activas. Aborda el defecto 3 del DiD (perspectiva de amenaza limitada — el DiD puro no incluye inteligencia de amenazas). Complementa directamente la limitación que el docente señala.

+ TLS (Transport Layer Security) (*control adicional — valor agregado*)

Qué es: Protocolo criptográfico que cifra las comunicaciones entre dos puntos en la red. Es el sucesor de SSL. Cuando ves "HTTPS" en un navegador, lo que hay por debajo es TLS.

Cómo funciona (simple):

1. El cliente (navegador/app) se conecta al servidor.
2. Negocian qué versión de TLS y qué algoritmos usar.
3. Intercambian certificados digitales para autenticarse.
4. Se establece un canal cifrado — nadie en el camino puede leer el contenido.

Versiones y por qué importa cuál usas:

Versión	Estado	Problema
SSL 3.0	✗ Obsoleto	Vulnerable — atacable con POODLE
TLS 1.0	✗ Obsoleto	Vulnerable — SBS y PCI-DSS lo prohíben
TLS 1.1	✗ Obsoleto	Vulnerable — mismo problema
TLS 1.2	✓ Aceptable	Seguro si está bien configurado
TLS 1.3	✓ Recomendado	Más rápido, más seguro, cifrado mejorado

En Bankitor, "hardening TLS" significa:

- Desactivar TLS 1.0 y 1.1 en el servidor web, WAF y APIs.
- Forzar uso de TLS 1.2 mínimo, idealmente TLS 1.3.
- Usar algoritmos de cifrado fuertes (AES-256, ChaCha20).
- Evitar suites de cifrado débiles (RC4, DES, 3DES).

Dónde aplica en Bankitor:

- Banca por Internet: todo el tráfico HTTPS debe ser TLS 1.2/1.3.
- Comunicación entre APIs internas: también cifrada con TLS.
- Conexión entre aplicación y BD de créditos: TLS en tránsito.

Relación con el modelo DiD: TLS protege la capa de Presentación (OSI capa 6) — es la TSI que garantiza confidencialidad e integridad del dato en tránsito. Complementa al WAF (que filtra contenido) y a la Auditoría SQL (que protege el dato en reposo).

+ NTP (Network Time Protocol) (*control adicional — valor agregado*)

Qué es: Protocolo que sincroniza los relojes de todos los dispositivos con una fuente de tiempo confiable.

Por qué es crítico para Bankitor: Si los relojes están desincronizados, los logs del SIEM no se pueden correlacionar correctamente. En el análisis forense de los incidentes, timestamps inconsistentes hacen imposible reconstruir la secuencia de eventos. Es un control básico de soporte al modelo DiD, no una TSI de seguridad en sí misma.

+ BCP / RTO / RPO (*control adicional — valor agregado*)

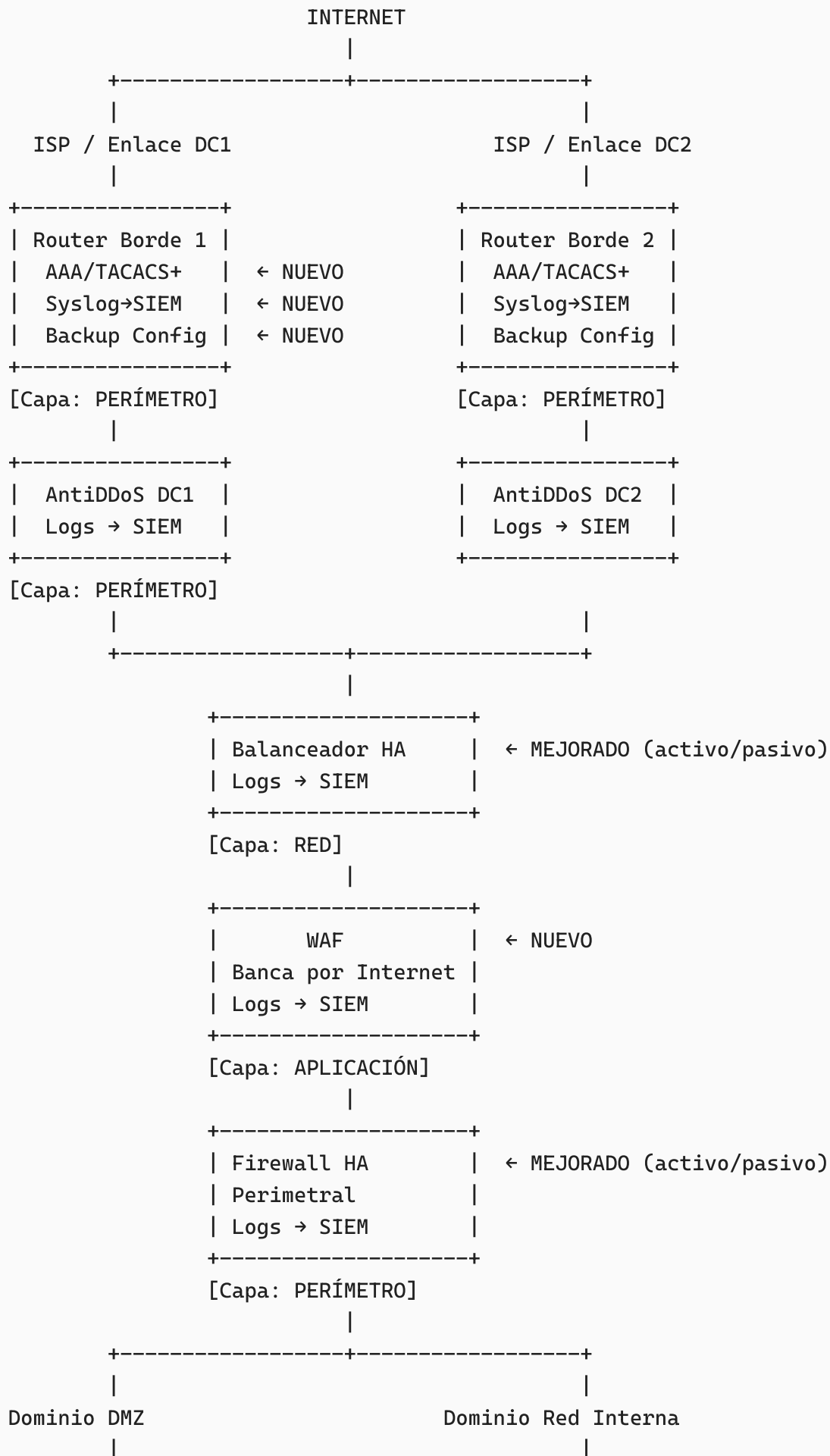
- **BCP (Business Continuity Plan):** Plan de continuidad del negocio.
 - **RTO (Recovery Time Objective):** Tiempo máximo aceptable para recuperar un servicio.
 - **RPO (Recovery Point Objective):** Cantidad máxima de datos que se puede perder.
-

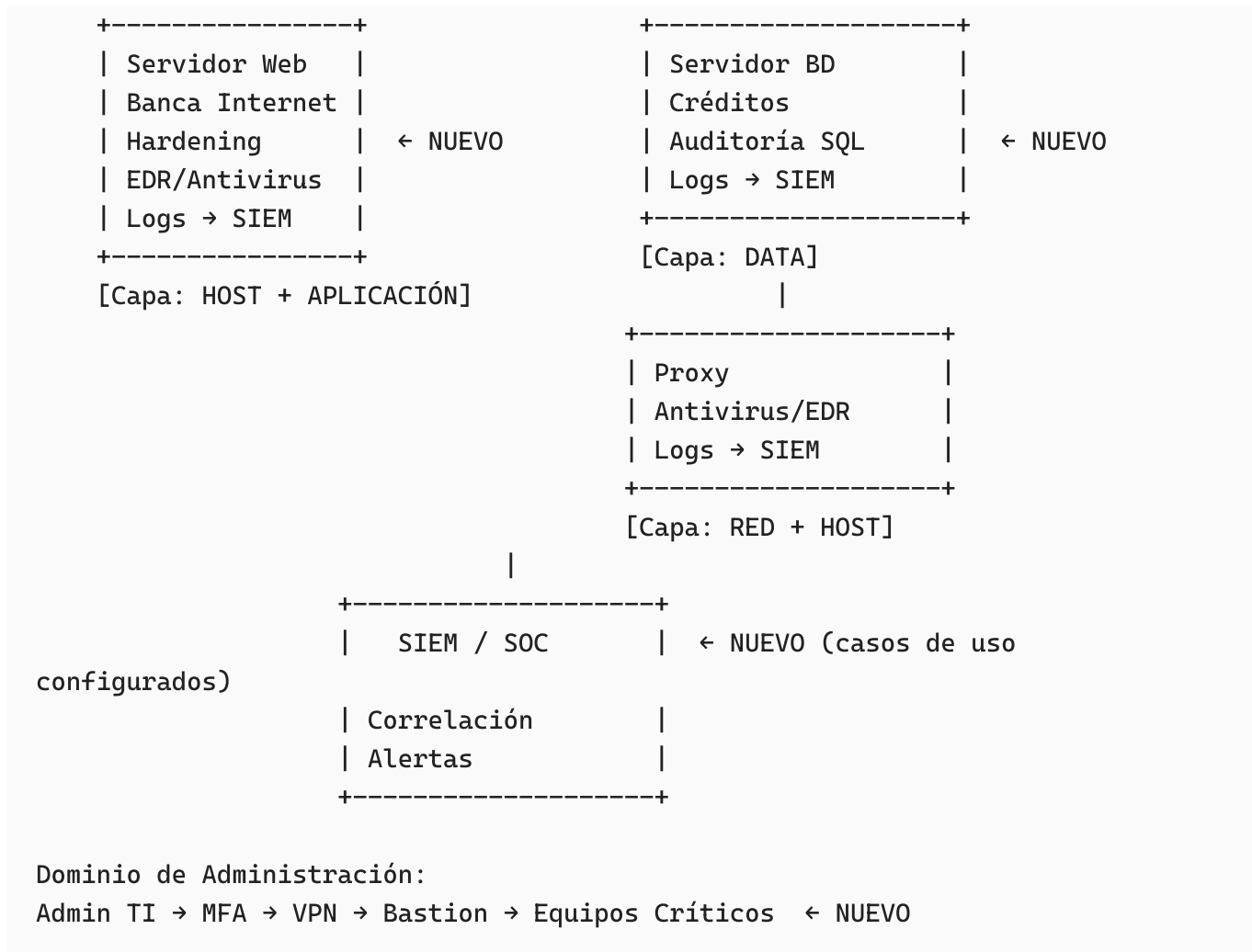
5. Corto Plazo (0–3 meses)

Objetivo: Cerrar de forma inmediata las brechas que ya causaron incidentes reales en el Business-Critical Subset de Bankitor, y reforzar los controles del dominio de seguridad perimetral antes de que ocurra una brecha en Banca por Internet.

Enfoque del modelo DiD aplicado: Priorizar las capas de Perímetro y Aplicación/Data, que son las que fallaron en los incidentes reales. Como enseña el docente: se secuencian actividades en base a la valoración de los activos afectados.

Diagrama de Arquitectura TO-BE — Corto Plazo





Controles del Corto Plazo — Mapeados al Modelo DiD

Control	Capa DiD	Resuelve
Router + AAA/TACACS+	Perímetro	Incidente 1: sin trazabilidad de comandos
Syslog centralizado	Todas	Permite análisis forense futuro
Backup de configuración	Perímetro	Rollback rápido ante cambios erróneos
WAF	Aplicación	Protege Banca por Internet (riesgo latente)
Auditoría SQL	Data	Incidente 2: sin registro de cambios en BD
Balanceador HA	Red	Elimina punto único de falla del AS-IS
Firewall HA	Perímetro	Elimina punto único de falla del AS-IS
MFA + VPN + Bastion	Perímetro	Punto de control de acceso administrativo
EDR en Servidor Web	Host	Detección de malware en activo de la DMZ
SIEM con casos de uso	Transversal	Correlación de eventos de todos los controles

Casos de Uso del SOC — Corto Plazo

Caso de Uso	Capa DiD	Prioridad
Cambio de configuración en router	Perímetro	Crítica
Login admin fuera de horario	Perímetro	Alta
Modificación masiva en BD créditos (>10 filas)	Data	Crítica
Ataques bloqueados por WAF	Aplicación	Alta
Caída de enlace ISP	Perímetro	Crítica
Acceso DBA desde IP no habitual	Data	Alta
Tráfico DMZ → Red Interna inusual	Red	Alta
Múltiples intentos de login fallidos	Aplicación	Media

Actividades — Corto Plazo

Mes 1 — Resolver incidentes reales (Business-Critical Subset)

- ☐ Configurar AAA/TACACS+ en routers de borde DC1 y DC2
- ☐ Activar Syslog en routers hacia SIEM
- ☐ Implementar backup automatizado de configuración de routers y firewalls
- ☐ Activar auditoría SQL en BD de créditos
- ☐ Configurar envío de logs de BD al SIEM

Mes 2 — Proteger Banca por Internet y accesos privilegiados

- ☐ Desplegar WAF para Banca por Internet (reglas OWASP Top 10)
- ☐ Implementar MFA para accesos VPN y cuentas administrativas
- ☐ Configurar Bastion Host con registro de sesiones
- ☐ Centralizar logs de antivirus existente en el SIEM

Mes 3 — Activar SIEM y eliminar puntos únicos de falla

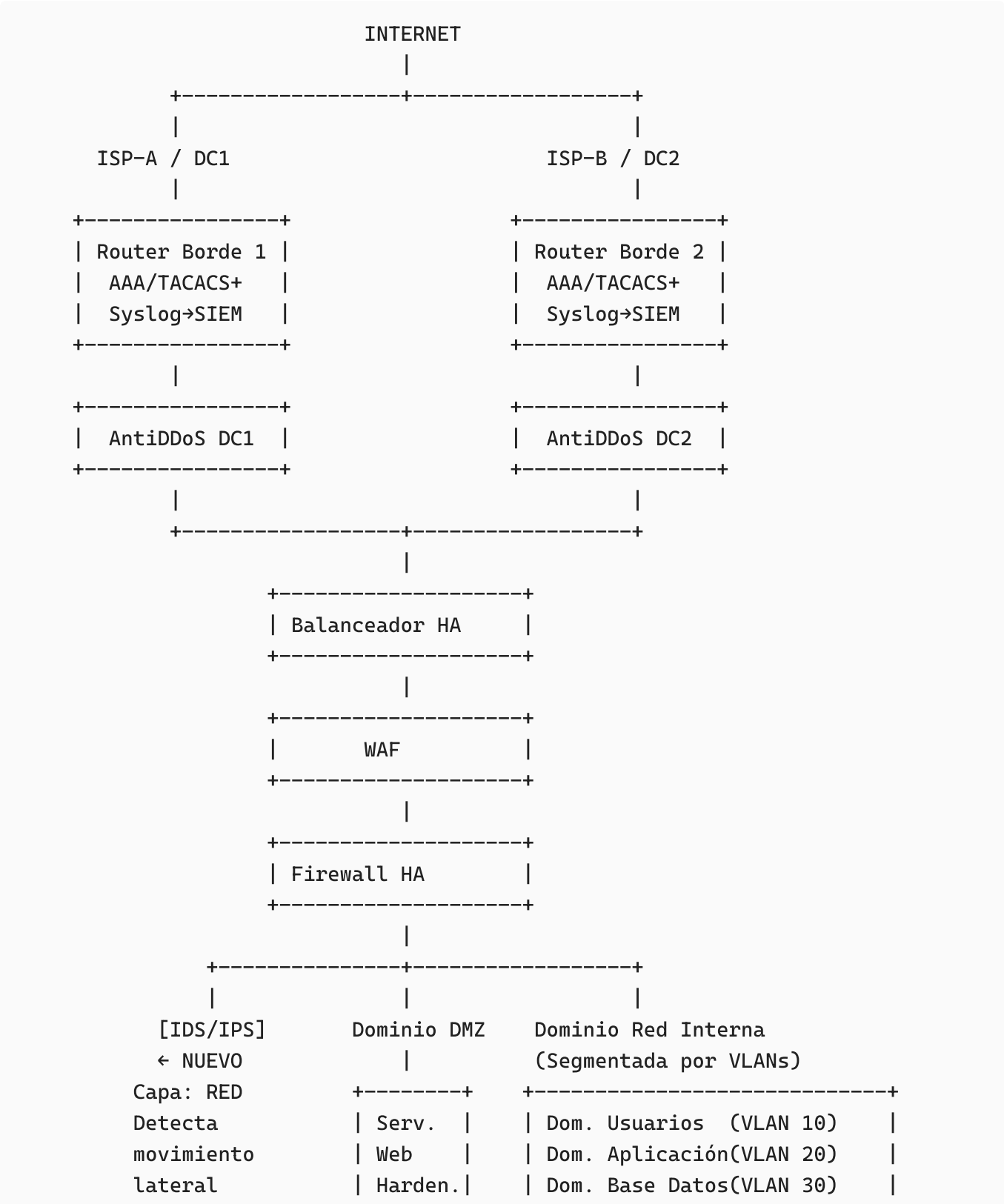
- ☐ Activar casos de uso críticos en el SIEM
- ☐ Realizar hardening del servidor web (TLS 1.2/1.3, puertos, servicios)
- ☐ Validar configuración HA del balanceador y del firewall
- ☐ Prueba de casos de uso con el SOC tercerizado

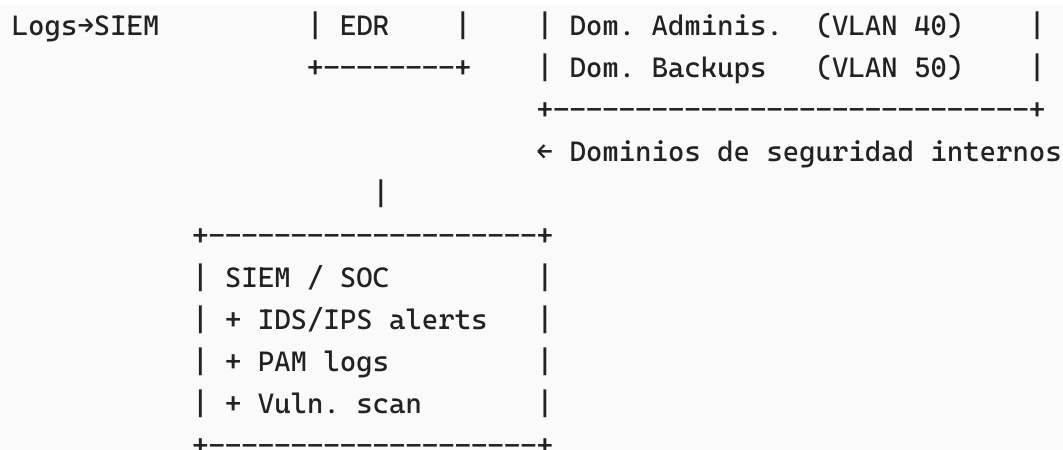
6. Mediano Plazo (3–6 meses)

Objetivo: Madurar los controles del modelo DiD, crear dominios de seguridad internos, implementar detección activa en la capa de Red y elevar el control sobre los accesos a activos críticos.

Punto de partida: Todo lo del corto plazo ya está operativo.

Diagrama de Arquitectura TO-BE — Mediano Plazo





Dominio de Administración:

Admin TI → MFA → PAM → Equipos Críticos (sesión grabada, contraseña rotada)

Nuevos controles del Mediano Plazo

IDS/IPS — Capa Red del DiD

Detección activa dentro de los dominios de seguridad, en puntos estratégicos:

- Entre Firewall Perimetral y DMZ (detecta ataques que pasaron el perímetro).
- Entre DMZ y Red Interna (detecta movimiento lateral entre dominios).

Nota sobre defecto 2 del DiD: El IDS/IPS **no** duplica al Firewall ni al WAF. El Firewall actúa en capa 3-4 por reglas. El WAF actúa en capa 7 para aplicaciones web. El IDS/IPS actúa en capa 3-7 con análisis de patrones de ataque. Cada uno cubre un vector distinto.

PAM — Capa Aplicación/Data del DiD

Reemplaza el Bastion básico del corto plazo. Agrega grabación de sesiones completas, rotación automática de contraseñas y acceso just-in-time. Punto de control sobre todos los accesos a activos críticos.

VLANs — Dominios de Seguridad Internos (Capa Red)

Corrección del mayor problema estructural del AS-IS: la red interna plana. Crear dominios de seguridad internos con puntos de control entre ellos.

Reglas entre dominios:

- Dom. Usuarios → Dom. Base Datos: **BLOQUEADO**
- Dom. Usuarios → Dom. Aplicación: permitido (puertos específicos)
- Dom. Aplicación → Dom. Base Datos: permitido (puertos específicos)
- Dom. Administración → todos: solo desde PAM

Gestión de Vulnerabilidades

Proceso formal de escaneo y remediación. Priorización por CVSS. Cierra brechas antes de que sean explotadas.

DLP Básico (Capa Data)

Control inicial sobre exfiltración de activos de información. Implementado en correo y proxy primero.

Casos de Uso SIEM Nuevos — Mediano Plazo

Caso de Uso	Capa DiD	Severidad
Escaneo de red detectado (port scan)	Red	Alta
Tráfico Dom. Usuarios → Dom. BD	Red	Crítica
Sesión PAM sin aprobación previa	Aplicación	Alta
Equipo con vulnerabilidad crítica sin parche	Host	Alta
Upload masivo a servicio externo	Data	Alta
Protocolo Telnet detectado	Red	Alta

Actividades — Mediano Plazo

Mes 4

- ☐ Implementar escáner de vulnerabilidades (primer escaneo del Business-Critical Subset)
- ☐ Diseñar dominios de seguridad internos (VLANs) con equipo de redes
- ☐ Evaluar y seleccionar solución PAM
- ☐ Primer simulacro de phishing a empleados

Mes 5

- ☐ Implementar segmentación de dominios de seguridad internos (VLANs)
- ☐ Instalar y calibrar IDS/IPS en puntos estratégicos
- ☐ Hardening de protocolos: desactivar Telnet, SSHv1, TLS 1.0/1.1; migrar a SNMPv3
- ☐ Sincronización NTP autenticada en todos los dispositivos (soporte al análisis forense)
- ☐ Iniciar implementación del PAM

Mes 6

- ☐ Completar integración del PAM con SIEM y MFA

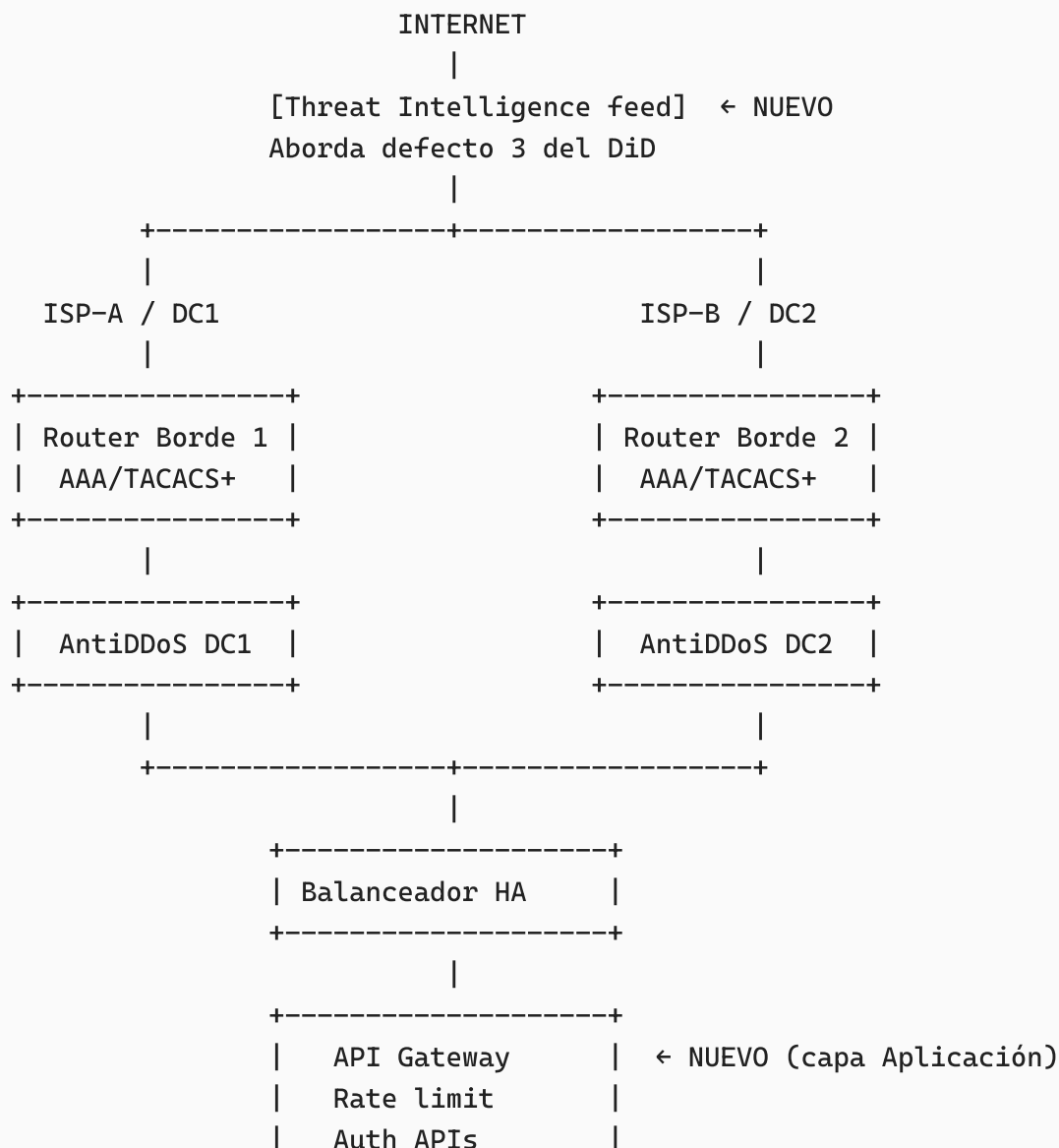
- ☐ Implementar DLP básico en correo y proxy
- ☐ Pruebas de continuidad: failover firewall, balanceador, ISP (documentar RTO/RPO)
- ☐ Capacitación formal a DBAs y administradores de red
- ☐ Actualizar casos de uso del SIEM con nuevas fuentes (IDS/IPS, PAM)

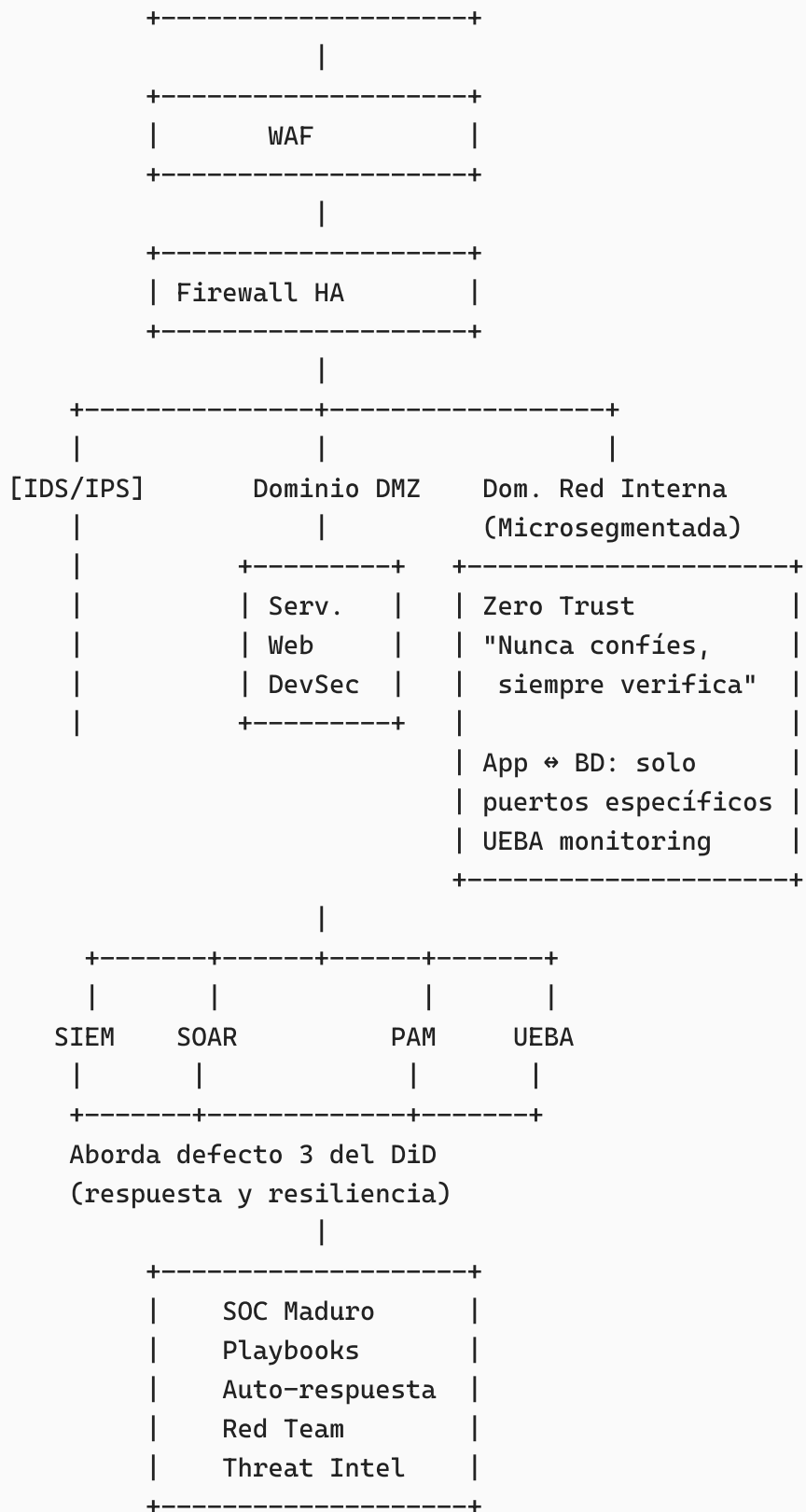
7. Largo Plazo (6–12+ meses)

Objetivo: Transformar la postura de Bankitor de reactiva a proactiva, incorporar inteligencia de amenazas (abordando el defecto 3 del DiD), automatizar la respuesta a incidentes y alcanzar madurez del SOC.

Punto de partida: Todo lo del corto y mediano plazo ya está operativo.

Diagrama de Arquitectura TO-BE — Largo Plazo





Gobierno: CISO → Comité Seguridad → Directorio → SBS
 DevSecOps: Código → SAST → SCA → DAST → Producción

Cómo el Largo Plazo corrige los 3 defectos del DiD

Defecto (docente)	Control en Largo Plazo
Defecto 1 — Arquitectura de red lineal	Microsegmentación: cada workload tiene su propio dominio de seguridad, no hay camino libre entre componentes
Defecto 2 — Capacidades superpuestas	API Gateway complementa al WAF (no lo duplica): WAF para ataques web, API Gateway para autenticación y control de APIs
Defecto 3 — Perspectiva de amenaza limitada	Threat Intelligence + SOAR + Red Team + UEBA: se incorporan inteligencia, respuesta y resiliencia

Nuevos controles del Largo Plazo

Zero Trust — Complemento al Modelo DiD

Modelo que extiende el DiD al dominio de identidad. "Nunca confíes, siempre verifica." Se construye progresivamente sobre los controles existentes:

Pilar Zero Trust	Control ya implementado
Identidad	MFA + PAM + verificación continua
Dispositivo	EDR + validación de postura del endpoint
Red	Microsegmentación (dominios por workload)
Aplicación	WAF + API Gateway
Data	DLP completo + cifrado

SOAR — Respuesta y Resiliencia (corrige defecto 3 del DiD)

Automatiza respuestas a incidentes conocidos. Ejemplos de playbooks:

Escenario	Acción automática
IP ataca WAF 100+ veces en 5 min	Bloquear IP en WAF y Firewall
Cuenta DBA activa fuera de horario	Suspender sesión + notificar + ticket
Modificación masiva en BD créditos	Bloquear acceso a BD + alerta al CISO
Malware detectado por EDR	Aislar equipo + análisis forense

Threat Intelligence — Inteligencia de Amenazas (corrige defecto 3 del DiD)

Consumo de feeds de amenazas activas. Incluye monitoreo dark web para detectar si credenciales de Bankitor están filtradas. El DiD clásico no incluía esto — es el complemento necesario.

Red Team / Ejercicios (corrige defecto 3 del DiD)

Validación real de todos los controles implementados. Simula las etapas del Cyber Kill Chain desde el punto de vista del atacante.

Actividades — Largo Plazo

Meses 7–8

- ☐ Implementar SOAR con primeros playbooks (bloqueo IP, aislamiento endpoint, escalamiento)
- ☐ Integrar Threat Intelligence al Firewall y WAF (bloqueo automático de IPs maliciosas)
- ☐ Implementar API Gateway para banca digital
- ☐ Iniciar diseño de microsegmentación (dominios por workload)

Meses 9–10

- ☐ Implementar UEBA sobre el SIEM existente
- ☐ Desplegar DLP endpoint en equipos de DBAs y administradores
- ☐ Realizar primer pentest completo (infraestructura + Banca por Internet)
- ☐ Implementar microsegmentación en servidores críticos (BD, Web)

Meses 11–12

- ☐ Implementar pipeline DevSecOps para nuevas aplicaciones
- ☐ Realizar ejercicio de Red Team (simula Kill Chain completo)
- ☐ Consolidar governance de seguridad: métricas KPI, comité, reportes al directorio
- ☐ Evaluar alineación con ISO 27001
- ☐ Documentar postura de seguridad para reporte regulatorio SBS

8. Evolución Total de la Arquitectura

Componente	AS-IS	Corto Plazo (3m)	Mediano Plazo (6m)	Largo Plazo (12m+)
Router	Sin trazabilidad (incidente 1)	AAA/TACACS+ + Syslog +	Igual + hardening	Igual + Threat Intel

Componente	AS-IS	Corto Plazo (3m)	Mediano Plazo (6m)	Largo Plazo (12m+)
		Backup	protocolos	
Firewall	Sin HA (SPOF)	HA + Logs SIEM	Igual + reglas por dominio	Igual + microsegmentación
Banca Internet	Sin WAF (riesgo latente)	WAF activo (OWASP Top 10)	WAF calibrado	WAF + API Gateway
Acceso admin	Directo (sin punto de control)	MFA + Bastion	PAM completo	PAM + Zero Trust
BD créditos	Sin auditoría (incidente 2)	Auditoría SQL	Igual + dominio aislado	Igual + enmascaramiento
Visibilidad	Sin SIEM	SIEM + casos base	SIEM + IDS/IPS + PAM	SIEM + SOAR + UEBA
Respuesta	Manual, tardía	SOC alertado	SOC con playbooks	SOAR automatizado
Segmentación	Red plana	Dominio DMZ vs Interna	Dominios por función (VLANs)	Microsegmentación por workload
Defecto 1 DiD	Sin dominios múltiples	Perímetro externo	Dominios internos	Microsegmentación
Defecto 2 DiD	Capacidades no alineadas	TSI por capa DiD	TSI no superpuestas	TSI optimizadas
Defecto 3 DiD	Sin inteligencia/respuesta	SOC básico	SOC madurando	Threat Intel + SOAR + Red Team

9. Indicadores de Madurez (KPIs)

KPI	Descripción	Objetivo
MTTD	Tiempo medio de detección	< 1 hora para incidentes críticos
MTTR	Tiempo medio de respuesta	< 4 horas para incidentes críticos

KPI	Descripción	Objetivo
Cobertura SIEM	% de activos críticos enviando logs	> 95%
Vulnerabilidades críticas sin parche	Vuln. críticas sin remediar en 72h	0
Sesiones PAM sin grabación	Sesiones privilegiadas no auditadas	0%
Accesos sin MFA a sistemas críticos	Sesiones sin segundo factor	0%
Ejercicios Red Team al año	Simulaciones Kill Chain completas	Al menos 1

10. Alineación Regulatoria

Normativa	Control implementado
Circular SBS G-140-2009 — Seguridad de Información	SIEM, auditoría SQL, control de accesos, trazabilidad (AAA/TACACS+)
Resolución SBS 272-2017 — Gestión de Riesgo Operacional	BCP, pruebas de continuidad, RTO/RPO documentados
Lineamientos de ciberseguridad SBS (2023)	SOC, gestión de vulnerabilidades, Zero Trust
NIST CSF — Identificar, Proteger, Detectar, Responder, Recuperar	Framework transversal a las 5 capas del DiD
ISO 27001 — SGSI	Marco de gobierno y gestión (objetivo largo plazo)

Documento consolidado: Arquitectura de Seguridad Bankitor — Corto, Mediano y Largo Plazo
Basado en la teoría de Defense in Depth (DiD) — Javier Benvenuto Servat, ESAN
Clasificación: Uso interno — Trabajo académico